

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	DAO tooling customer, governance platform, or organization operating wallet-g
Management units responsible	Product; Governance Operations; Legal / Compliance; Security
DPO or similar function	Customer DPO or privacy contact where applicable

Processor(s) and Sub-processor(s)

#	Processor	Obligations and Tasks
1	co-mission LLC / Shyware	Provides shares/governance SDK, account commitment utilities, optional h
2	Wallet / blockchain provider	Provides wallet address, signature, account, membership, or chain data dep
3	Cloud infrastructure provider	Hosts API, governance snapshots, canonical node, database, and security se
4	Identity or KYB provider	Optional provider for verified organizations, admins, or high-assurance men

Name of the Processing

Internal name: Shyware DAO / Wallet Governance DPIA

Repository evidence: Consumers/BIGGLOM; shyware/sdk/web/clients/embodiments/sharesClient.js; shyware/services/identity/wallet.go; Consumers/BIGGLOM/webapp/src/services/mySharesState.js; patent/mainhub/dpia/evidence_index.md.

DPIA Technical Sheet

Field	Value
Current version	0.1 draft
Reason to conduct DPIA	Wallet governance can expose account membership, voting weight, delegated influen
Scope	DAO governance and wallet eligibility flows using account commitments, membersh
Publication	Internal domain DPIA; customer-specific adaptation required

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category	Sp
1	Wallet address or account identifier	Blockchain account, EVM address, or customer account id	No
2	Account commitment	Hash or commitment derived from wallet/account	Pse
3	Membership snapshot	Organization membership, role, voting weight, delegated weight	No
4	Ballot or governance choice	Proposal vote, preference, weighted decision	Pot
5	Receipt / local ballot state	Local storage of proposal receipt and account commitment	Pse
6	Admin/KYB data	Organization admin, beneficial ownership, or verification status	Pot

Purposes of the Processing

#	Purpose	Legal Basis Assumption
1	Eligibility-gated DAO or organization governance	Contract / legitimate interests / customer-specific b
2	Weighted voting and delegated governance execution	Contract / legitimate interests
3	Membership and role display to authorized user	Contract / legitimate interests
4	Auditability of aggregate governance result	Legitimate interests / legal obligation depending org

Nature, Scope and Context The processing supports wallet or account-based governance. BIGGLOM code reads organizations, membership snapshots, account commitments, voting weight, delegated weight, and local receipts. Wallet-derived identity may be pseudonymous but often links to public on-chain history, assets, governance participation, and associations.

Mainhub Patent Alignment The Mainhub patent architecture can reduce canonical-state linkage between a governance choice and an account commitment where the two-list rejection predicate is implemented. It does not erase public wallet history, membership graphs, delegated-weight relationships, token holdings, local receipts, or customer governance disclosures. Wallet-derived identity should therefore be treated as a linkability and profiling risk even when canonical vote-choice linkage is minimized.

Authority Partition This is a count-match embodiment with wallet/DID-based identity rather than biometric KYC. Four structurally separated parties are required:

Authority	Role
Auth (Cognito or wallet)	Account layer; alwa
Credential authority (Identus DID or wallet provider)	Attests member ide
Eligibility authority (DAO governance administrator or designated governance authority)	Determines member

Authority	Role
Reconciling authority	Off-chain linkage st

Dual co-authorization enforcement (Claim 2): The validation layer must reject single-signature rescission transactions. **VERIFIED (run 26369476939):** *DUAL_COSIG* section passes 379/379 — *unauthenticated + valid token* → 401; *authenticated + no token* → 400; *both co-signatures* → 200, *countMatch* preserved.

Functional Description

Phase	Operation	Explanation
Eligibility	User provides wallet/account or verified membership signal	SDK derives acco
Membership read	App retrieves organizations and membership snapshot	Displays roles, vo
Ballot build	User submits weighted governance choice	Choice should be
Canonical write	Runtime records anonymous choice and participant/commitment record	Count-match or n
Receipt	Client writes local receipt keyed by proposal and account commitment	Local storage mu

ANALYSIS OF THE PROCESSING

Lawfulness of the Processing

Customer controllers should identify whether the deployment is a private organization governance tool, public DAO governance surface, employee/member governance system, financial protocol, or political/community association. The legal basis and sensitivity change materially across those contexts.

Data Minimisation, Retention Periods, and Data Quality

Data Item	Minimisation Position	Open Review
Wallet address	Avoid storing raw wallet address where account commitment is sufficient	Add wallet p
Account commitment	Scope commitment to organization/proposal where feasible	Avoid cross-
Membership snapshot	Store only active eligibility and weight needed for vote	Define snaps
Delegated weight	Expose only to authorized governance surfaces	Assess profil
Local receipt	Keep local, user-controlled, and erasable	Define brow

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The processing can be proportionate where governance participation requires membership and weight verification. Reusable wallet identifiers, public on-chain history, and delegated-weight graphs create additional linkability risk and should be minimized by scoped commitments and limited retention.

RISK ASSESSMENT AND MANAGEMENT

Risk Assessment and Management

Threats

#	Threat	Materialisation
1	Wallet deanonymization	Account commitment or receipt linked back to public wallet history
2	Governance preference exposure	Vote choice linked to wallet, role, or delegated-weight profile
3	Membership profiling	Organization membership and role expose affiliations or power structure
4	Inaccurate eligibility	Stale membership snapshot or unverified wallet control allows wrong par
5	Local receipt compromise	Browser storage exposes proposal/account participation

Additional Mitigating Measures

#	Measure	Status
1	Require wallet ownership proof before production use of wallet identity mode	See patent
2	Scope account commitments per organization and proposal where feasible	See patent
3	Define membership snapshot retention and correction process	See patent
4	Provide local receipt clear/export controls	See patent
5	Document whether governance votes are public, pseudonymous, or unlinkable per deployment	See patent

DPIA Audit Findings This DPIA is the audit record for the DAO, wallet, and delegated governance processing pattern. The following findings must be resolved in this DPIA or in a customer-specific version before production.

Audit Area	Required Finding
Patent posture	Write-side canonical state may reduce account–governance-choice linkage only if
Protected linkage / reconcile	Delegation, recovery, reveal, or adverse-action workflows must be single-subject,
Provider partitioning	Identify wallet verifier, IDV/auth provider if any, linkage store, reconciling auth
Wallet linkability	Wallet history, token holdings, delegation graph, or public account activity may
Governance fairness	Weighting, delegation, eligibility snapshots, and challenge processes may create p
Residual risk	This DPIA cannot be approved for production until identity mode, delegation m

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** ([patent/mainhub/dpia/source/COM](https://shyware.fyi/legal) published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.

- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to shyconfig.json; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that eligibility_authority_key $\neq$ reconciling_authority_key $\neq$ auth_key.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while DAO/wallet governance choices, wallet-linkability exposure, delegation rules, fairness, appeal, or adverse-action workflows still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Wallet/account re-identification	Scoped commitments, wallet minimization, notice, and no reusable c
Delegation or governance profiling	Payload minimization, retention limits, and controller governance ru
Recovery/reveal misuse	Non-enumerable reconcile API, audit logs, provider partitioning
Eligibility or weighting unfairness	Snapshot rules, challenge process, and human review
Provider consolidation	Provider matrix for wallet verifier, IDV/auth, linkage, reconcile, con
Adverse-action or freeze workflow misuse	Typed action limits, audit logs, customer approval, and appeal proc

INVOLVEMENT OF INTERESTED PARTIES

Customer governance admins, DAO representatives, member representatives, and privacy/security stakeholders should review this DPIA. Consultation is especially important where governance concerns employment, political association, financial protocol control, or member benefits.

CONCLUSION AND DECISION

Draft decision: Separate DPIA required before production deployment. Proceed only after wallet proof, commitment scoping, membership snapshot retention, receipt handling, and public/private governance disclosure posture are fixed.